INSTITUTO UNIVERSITÁRIO DE LISBOA

Mestrado em Engenharia Informática

Segurança em Redes e Sistemas de Informação

Segurança em Camadas para Comunicações IoT Baseadas em MQTT

Revisão Crítica, Arquitetura Modular e Plano de Avaliação

Projeto — Parte 1: entrega teórica

Autores:

Rodrigo Gorjão, N.º 82972
João Afonso, N.º 97990
João Tendeiro, N.º 129087
Jossivalter Leal, N.º 146851

Data: 17-10-26

Docente: Daniel Maximino Caçador

Repositório: `https://github.com/joaoaeafonso/mqtt_secure`

Resumo

O MQTT é um dos protocolos de mensagens mais usados na Internet das Coisas, mas deixa a segurança à implementação. Como todas as mensagens atravessam um *broker*, o TLS não basta: termina no próprio *broker*, que vê todo o conteúdo, e não impede a repetição de mensagens nem o abuso de uma chave comprometida. Este trabalho apresenta uma revisão sistemática da literatura sobre mecanismos de segurança para o MQTT, conduzida segundo um protocolo explícito (perguntas de investigação, PICOC, *strings* de pesquisa, critérios de inclusão e exclusão, e extração de dados). As pesquisas no IEEE Xplore, no Scopus e no ScienceDirect devolveram 2450 registos únicos, triados por título e resumo; 19 estudos primários (2015–2026) e cinco revisões relacionadas foram analisados em texto integral, classificados numa taxonomia de oito categorias e comparados pelas propriedades de segurança que garantem. A literatura trata sobretudo confidencialidade, autenticação e integridade. A validade temporal, a deteção de duplicados, a ligação ao tópico e o não repúdio existem, mas isolados em poucos estudos, e a maioria das soluções confia no *broker*. Daqui resulta a proposta: propõe-se uma arquitetura em camadas comutáveis, com defesa no transporte, um envelope fim-a-fim com AES-256-GCM (ou ChaCha20-Poly1305) ou Ed25519 e limitação de tráfego antes de qualquer operação criptográfica, e planeia-se a segunda parte do projeto: medir, num Raspberry Pi, o custo e os ataques impedidos por cada camada, para escolher a configuração com a maior proteção e o menor impacto no desempenho.

Palavras-chave: MQTT; Internet das Coisas; segurança fim-a-fim; cifra autenticada; revisão sistemática da literatura; defesa em profundidade.

Índice

Resumo **i**

1 Introdução **1**
1.1 Contexto . . . 1
1.2 Problema . . . 1
1.3 Objetivos e estrutura . . . 1

2 Enquadramento teórico **2**
2.1 O protocolo MQTT . . . 2
2.2 Segurança nativa do MQTT e dos *brokers* . . . 2
2.3 Primitivas criptográficas . . . 3
2.4 Validade temporal e proteção contra repetição . . . 3
2.5 Limitação de tráfego . . . 4
2.6 Modelo de ameaças . . . 4

3 Metodologia: protocolo da revisão sistemática **5**
3.1 Perguntas de investigação . . . 5
3.2 Critérios PICOC . . . 5
3.3 *String* de pesquisa e bases de dados . . . 5
3.4 Critérios de inclusão e exclusão . . . 6
3.5 Seleção dos estudos e avaliação da qualidade . . . 6
3.6 Extração de dados . . . 8

4 Trabalhos relacionados: revisões existentes **8**

5 Resultados da revisão **9**
5.1 Caracterização dos estudos (QE1, QE2) . . . 9
5.2 Taxonomia das soluções (QF2) . . . 10
5.2.1 C1 — Análise de vulnerabilidades e ataques . . . 10
5.2.2 C2 — Autenticação . . . 11
5.2.3 C3 — Autorização e controlo de acesso . . . 11
5.2.4 C4 — Cifra baseada em atributos . . . 11
5.2.5 C5 — Proteção leve fim-a-fim da mensagem . . . 11
5.2.6 C6 — Proteção do *broker* e do transporte . . . 12
5.2.7 C7 — Deteção de intrusões . . . 12
5.2.8 C8 — Privacidade e anonimato . . . 12
5.3 Comparação dos mecanismos (QF3, QF4) . . . 12
5.4 Respostas às perguntas de investigação . . . 14

6 Proposta: arquitetura de segurança em camadas **15**
6.1 Princípios de desenho . . . 15
6.2 Arquitetura em camadas . . . 15

6.3 Camada de transporte e *broker* 15
6.4 Envelope fim-a-fim 15
6.5 Ordem de verificação no recetor 17
6.6 Validade temporal e anti-repetição 17
6.7 Restrição chave–tópico 17
6.8 Gestão de chaves 18
6.9 Limitação de tráfego antes da criptografia 18
6.10 Comparação com os trabalhos relacionados 18
6.11 Limitações conhecidas 19

7 Objetivo e plano da segunda parte do projeto 19
7.1 Perguntas experimentais 19
7.2 Configurações em estudo 19
7.3 Plataforma experimental 20
7.4 Métricas 20
7.5 Critério de escolha da melhor configuração 20
7.6 Procedimento e hipóteses 22

8 Discussão 23
8.1 Lacunas do estado da arte 23
8.2 Ameaças à validade 24

9 Conclusões e trabalho futuro 24

A *Strings* de pesquisa por base de dados 30

B Extração de dados e referências dos estudos 30

1 Introdução

1.1 Contexto

O *Message Queuing Telemetry Transport* (MQTT), normalizado pela OASIS nas versões 3.1.1 [1] e 5.0 [2], é um dos protocolos de mensagens mais usados na Internet das Coisas (IoT) [3]. Segue o paradigma publicação/subscrição: um *publisher* envia mensagens para um *tópico* (por exemplo, `fabrica/sala1/temperatura`) e um intermediário, o *broker*, entrega-as a todos os clientes subscritos. Os clientes nunca comunicam diretamente uns com os outros. Existem implementações abertas e conformes à norma, como o Eclipse Mosquitto [4].

1.2 Problema

A especificação deixa a segurança à implementação, que a obtém tipicamente com TLS (*Transport Layer Security*) [1, §5]; oferece nome de utilizador e palavra-passe na ligação, mas não protege a mensagem em si. Daqui resultam três problemas.

P1. O *broker* é um ponto de confiança total. O TLS protege apenas cada salto cliente–*broker* [5]. No *broker*, as mensagens existem em claro [6]: quem o comprometer vê todo o tráfego, e um cliente autorizado a subscrever o filtro `#` recebe as mensagens de todos os tópicos que não começam por `$` [1, §4.7].

P2. Uma mensagem autêntica pode ser repetida ou desviada. A autenticação não impede que uma mensagem válida seja capturada e repetida mais tarde, nem publicada noutro tópico. São precisos, em separado, validade temporal, anti-repetição e ligação ao tópico.

P3. Comprometimento de dispositivos. Se uma chave válida puder publicar em qualquer tópico, um único dispositivo comprometido faz-se passar por todos os outros.

A pergunta que a revisão procura responder é: *que mecanismos de segurança propõe o estado da arte para comunicações baseadas em MQTT, que propriedades garantem e que lacunas persistem?*

1.3 Objetivos e estrutura

O1. Conduzir uma revisão sistemática da literatura (RSL) com um protocolo explícito e reprodutível [7, 8].

O2. Classificar as soluções numa taxonomia, compará-las por propriedade de segurança e compará-las com as revisões já publicadas.

O3. Propor, a partir das lacunas, uma arquitetura de segurança em camadas.

O4. Definir o plano da segunda parte do projeto: medir, num Raspberry Pi, o custo e o benefício de cada camada.

A Secção 2 apresenta os fundamentos, a Secção 3 o protocolo da revisão, a Secção 4 as revisões existentes e a Secção 5 os resultados. A Secção 6 propõe a arquitetura, a Secção 7 planeia a segunda parte, a Secção 8 discute as lacunas e as ameaças à validade, e a Secção 9 conclui.

2 Enquadramento teórico

2.1 O protocolo MQTT

O MQTT funciona sobre um transporte ordenado e fiável, normalmente TCP (porta 1883) ou TLS (porta 8883) [1]. Os clientes não se conhecem entre si, o que torna o protocolo escalável, mas concentra a confiança no *broker* (Figura 1).

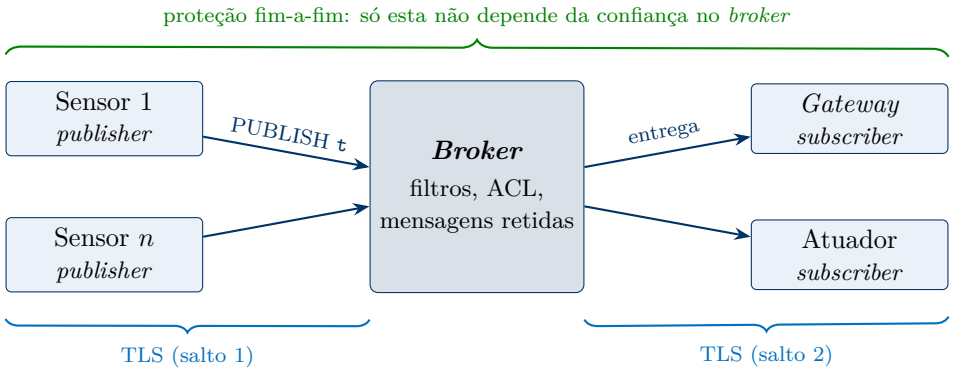


Figura 1. Arquitetura de publicação/subscrição do MQTT. O TLS protege cada salto em separado e termina no *broker*; só a proteção fim-a-fim da mensagem sobrevive a um *broker* não confiável.

Tópicos e filtros. Os tópicos são cadeias hierárquicas separadas por `/`. As subscrições usam *filtros* com dois carateres especiais: `+` corresponde a exatamente um nível e `#`, só no fim, a qualquer número de níveis. Tópicos começados por `$` (como `$SYS/...`) não são abrangidos por filtros que comecem por um destes carateres [1, §4.7]. Escreve-se $\mathrm{corr}(f, \tau)$ quando o filtro f corresponde ao tópico τ segundo estas regras.

Qualidade de serviço e retenção. O QoS 0 entrega no máximo uma vez, o QoS 1 pelo menos uma vez (com possíveis duplicados) e o QoS 2 exatamente uma vez [1, §4.3]. Os duplicados legítimos do QoS 1 são indistinguíveis de uma repetição maliciosa, uma tensão que a proposta tem de resolver. O *broker* pode ainda reter a última mensagem de cada tópico [1, §3.3.1.3] e manter sessões persistentes, ou seja, armazena conteúdo, o que agrava o problema P1.

2.2 Segurança nativa do MQTT e dos *brokers*

Nenhum destes mecanismos protege a *mensagem* de ponta a ponta (Tabela 1). É neste espaço que se situa a maior parte das propostas da literatura e a arquitetura proposta.

Tabela 1. Mecanismos de segurança nativos do MQTT e dos *brokers* e respetivas limitações.

Mecanismo	O que oferece	Limitação
Utilizador e palavra-passe (CONNECT)	Autenticação do cliente pelo *broker*	Em claro sem TLS [1, §5.4.1]; não autentica mensagens individuais
TLS [5]	Confidencialidade e integridade de cada salto	Termina no *broker*; custo no estabelecimento da ligação, sobretudo com perdas de pacotes [9]; um cliente só controla o seu próprio salto [10]
TLS mútuo (mTLS)	Autenticação forte do cliente por certificado	Exige infraestrutura de chave pública e revogação
Listas de controlo de acessos (ACL)	Autorização por tópico no *broker*	Não protegem contra o próprio *broker*
AUTH (MQTT 5) [2, §4.12]	Autenticação por desafio–resposta	Só autentica a ligação; não protege o conteúdo

2.3 Primitivas criptográficas

Cifra autenticada (AEAD). Uma cifra AEAD garante, numa só operação, a confidencialidade do texto e a autenticidade do texto e de dados associados que seguem em claro:

$$(C, T) = \mathrm{AEAD.Enc}(K, N, P, A), \qquad \mathrm{AEAD.Dec}(K, N, C, T, A) \in \{P, \perp\}, \tag{1}$$

com chave K, *nonce* N, texto P, dados associados A, criptograma C e etiqueta T. Como A é autenticado sem ser cifrado, permite ligar à mensagem metadados que têm de ficar legíveis, como o cabeçalho ou o tópico.

AES-GCM e GMAC. O AES-GCM (*Advanced Encryption Standard* em modo *Galois/Counter*) é a AEAD normalizada pelo NIST [11]; com P vazio, obtém-se o GMAC (*Galois Message Authentication Code*). A sua segurança colapsa se o mesmo par (K, N) for usado duas vezes, o que permite falsificar etiquetas [12]. Com *nonces* aleatórios, o NIST limita a 2^{32} o número de cifras por chave [11, §8.3], pelo que esquemas de longa duração precisam de rotação de chaves. O ChaCha20-Poly1305 [13] é a alternativa para processadores sem AES em *hardware*.

MAC e assinaturas. Um código de autenticação de mensagem (MAC), como o HMAC (*keyed-Hash MAC*) [14], dá integridade e autenticidade, mas *não* prova a origem: qualquer detentor da chave, incluindo o recetor, pode produzir a mesma etiqueta. Uma assinatura Ed25519 [15, 16] (64 octetos) só pode ser produzida com a chave privada e é verificável com a pública, pelo que dá *prova de origem*, a base técnica do não repúdio.

2.4 Validade temporal e proteção contra repetição

Validade temporal. Uma mensagem com carimbo temporal autenticado t_m, recebida no instante t, é aceite por um recetor com tolerância de idade Δ_a e de desvio de relógio Δ_s sse

$$t - \Delta_a \;\le\; t_m \;\le\; t + \Delta_s. \tag{2}$$

Isto limita o tempo em que uma mensagem capturada é útil, mas não impede a repetição dentro da janela Δ_a.

Janela anti-repetição. O mecanismo do IPsec ESP [17, §3.4.3] mantém, por remetente, o maior número de sequência aceite h e um mapa de bits W de largura w (64 é o valor recomendado), em que $W_i = 1$ significa que $h - i$ já foi recebido. Uma mensagem autêntica com número s é aceite sse

$$s > h \quad \vee \quad \big(0 \le h - s < w \ \wedge \ W_{h-s} = 0\big), \tag{3}$$

e o estado é então atualizado. O mecanismo tolera reordenação até w posições. O estado só pode ser atualizado *depois* de verificada a autenticidade [17, §3.4.3]; caso contrário, um atacante avança a janela com números forjados.

2.5 Limitação de tráfego

O balde de testemunhos (*token bucket*) [18, §3] limita a taxa média a ρ mensagens por segundo, com rajadas até β. O número de testemunhos no instante t, dado o último acesso em t_0, é

$$b(t) = \min\big(\beta,\ b(t_0) + \rho\,(t - t_0)\big), \tag{4}$$

e uma mensagem é aceite sse $b(t) \ge 1$, gastando um testemunho. A RFC 2697 conta octetos; aqui conta-se uma mensagem por testemunho.

2.6 Modelo de ameaças

Distinguem-se quatro posições do adversário, que não têm os mesmos poderes e serão ensaiadas em separado:

- **Atacante na rede**: observa, altera, injeta e repete tráfego nos percursos entre clientes e *broker*.
- **Cliente malicioso**: liga-se ao *broker*, eventualmente com uma credencial legítima de permissões limitadas, e tenta publicar, subscrever, repetir mensagens, reivindicar a identidade de outro cliente e consumir recursos.
- ***Broker* curioso ou ativo**: o curioso segue o protocolo mas lê o que lhe passa; o ativo pode também alterar, redirecionar, repetir, atrasar ou suprimir mensagens.
- **Dispositivo comprometido**: o adversário conhece as chaves e as permissões desse dispositivo, mas não as dos restantes, e produz mensagens criptograficamente válidas dentro desse âmbito.

Limites da proteção. Há ameaças que nenhuma camada adicional resolve e que, por isso, ficam fora das garantias da proposta. Um *broker* ativo pode sempre suprimir entregas, e a criptografia não repõe essa disponibilidade. Cifrar o conteúdo não oculta ao *broker* o tópico, que segue no cabeçalho variável do PUBLISH [1, §3.3.2.1], nem o tamanho e a frequência das mensagens. Um dispositivo comprometido pode publicar dados falsos nos tópicos para os quais está autorizado.

A Tabela 2 organiza as ameaças segundo as categorias STRIDE (*Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege*) [19]; cinco delas coincidem com as classes de problemas que Hintaw et al. [20] identificam no MQTT, e acrescenta-se o repúdio.

Tabela 2. Ameaças ao MQTT segundo a classificação STRIDE e mecanismos que as mitigam.

Categoria	Ameaça no MQTT	Mitigação típica
Spoofing	Cliente reivindica a identidade de outro; mensagens injetadas em tópicos alheios	Autenticação (palavras-passe, mTLS); autenticação da mensagem; restrição chave–tópico
Tampering	Alteração do conteúdo, do cabeçalho ou do tópico	TLS (por salto); AEAD, MAC ou assinatura com o tópico nos dados associados
Repudiation	Remetente nega ter enviado; recetor fabrica mensagens em nome do remetente	Assinaturas digitais (um MAC partilhado não basta)
Information disclosure	Subscrição de `#`; *broker* curioso	ACL; cifra fim-a-fim; ambiente de execução confiável (TEE) no *broker* [6]
Denial of service	Inundação; ligações lentas [21]; esgotamento de estado	Limitação de tráfego; estado limitado; deteção de intrusões [22]
Elevation of privilege	Chave de um dispositivo usada para publicar por outros	ACL com identidade autenticada; restrição chave–tópico; revogação

Nenhum mecanismo isolado cobre todas as categorias, o que justifica a **defesa em profundidade**: combinar mecanismos independentes no transporte, na mensagem e na disponibilidade, de modo que a falha de um deles não deixe o sistema sem proteção.

3 Metodologia: protocolo da revisão sistemática

A revisão segue as diretrizes de Kitchenham e Charters [7], em três fases (planeamento, condução e relato), e relata a seleção dos estudos com o diagrama PRISMA 2020 (*Preferred Reporting Items for Systematic Reviews and Meta-Analyses*) [8].

3.1 Perguntas de investigação

As perguntas (Tabela 3) dividem-se numa pergunta geral, que define *o que* se investiga, em perguntas focadas, sobre *como* os problemas são tratados, e em perguntas estatísticas, que quantificam *quanto* é feito.

3.2 Critérios PICOC

3.3 *String* de pesquisa e bases de dados

A partir das perguntas identificaram-se grupos de ideias e os respetivos sinónimos (Tabela 5); os termos de um grupo combinam-se com `OR` e os grupos entre si com `AND`. A *string* principal combina G1, G2 e G3 no título, resumo e palavras-chave; a secundária acrescenta G4, para encontrar revisões já publicadas. A *string* principal inclui `"MQTT-SN"`, porque há soluções para a variante para redes de sensores [23, 24], e `"intrusion"`, porque a deteção de intrusões é uma linha própria [22, 25].

Tabela 3. Perguntas de investigação.

ID	Pergunta
QG	Que mecanismos de segurança propõe a literatura para comunicações IoT baseadas em MQTT e que propriedades garantem?
QF1	Que ameaças e vulnerabilidades do MQTT são identificadas?
QF2	Que mecanismos são propostos e onde atuam (transporte, *broker*, mensagem fim-a-fim, deteção)?
QF3	Que propriedades garantem e assumem um *broker* confiável?
QF4	Como são avaliadas as soluções?
QF5	Que limitações e desafios em aberto são reportados?
QE1	Quantas publicações existem por ano?
QE2	Qual a distribuição por tipo de publicação?
QE3	Quantos estudos abordam cada categoria e cada propriedade?

Tabela 4. Âmbito da revisão segundo os critérios PICOC.

Critério	Definição nesta revisão
Population	Comunicações IoT baseadas em MQTT ou MQTT-SN (MQTT para redes de sensores): clientes e *brokers*.
Intervention	Mecanismos de segurança: criptográficos, de autenticação e autorização, de proteção do *broker*, de deteção e de privacidade.
Comparison	MQTT com a segurança nativa ou apenas com TLS; mecanismos propostos entre si.
Outcome	Propriedades garantidas, ameaças mitigadas, custo e tipo de avaliação.
Context	Investigação com revisão por pares, de 2014 (normalização do MQTT 3.1.1) a 2026.

As pesquisas foram feitas no IEEE Xplore, no Scopus e no ScienceDirect, em 01-11-2026; a adaptação da *string* a cada base consta do Anexo A. O ScienceDirect, por não suportar o carácter ∗ e limitar os operadores booleanos, exigiu dividir a *string* principal em duas consultas, e a secundária, que excede esse limite, não pôde ser executada. O ACM Digital Library e a Web of Science, previstos no protocolo, não foram pesquisados: o primeiro exige subscrição para exportar resultados e a segunda não esteve acessível; as atas ACM relevantes para o tema (por exemplo, ARES, SaT-CPS e ICPE) estão indexadas no Scopus. Os registos foram exportados de cada base, com resumo, e processados com um *script* próprio, disponível no repositório [26], que remove os tipos de documento não admitidos pelo CI2 (normas, revistas de divulgação e capítulos de livro) e os duplicados, por DOI e, na falta deste, por título normalizado. A Tabela 6 regista os registos devolvidos por cada base.

3.4 Critérios de inclusão e exclusão

Um estudo é incluído se satisfizer *todos* os critérios de inclusão e *nenhum* dos de exclusão (Tabela 7). A versão em conferência do protocolo baseado em AugPAKE (*Augmented Password-Authenticated Key Exchange*) [27] foi considerada elegível na triagem, mas analisou-se apenas a versão em revista [28], que os autores apresentam como alargada a partir dela [28, §I] (CE2).

3.5 Seleção dos estudos e avaliação da qualidade

Triagem. Removidos os duplicados e os tipos não admitidos, os 2450 registos foram classificados por título e resumo por um único revisor, aplicando os critérios que não exigem o texto integral

Tabela 5. Grupos de ideias e sinónimos usados na *string* de pesquisa.

Grupo	Termos (combinados com OR)
G1 — Protocolo	`"MQTT"`, `"MQTT-SN"`, `"MQ Telemetry Transport"`, `"Message Queuing Telemetry Transport"`, `"Message Queue Telemetry Transport"`
G2 — Segurança	`"security"`, `"secure"`, `"authentication"`, `"authorization"`, `"access control"`, `"encryption"`, `"confidentiality"`, `"integrity"`, `"privacy"`, `"attack*"`, `"vulnerabilit*"`, `"intrusion"`
G3 — Domínio	`"Internet of Things"`, `"IoT"`, `"IIoT"`, `"publish/subscribe"`, `"publish-subscribe"`, `"machine-to-machine"`, `"M2M"`
G4 — Revisões (só na secundária)	`"systematic literature"`, `"systematic review"`, `"literature review"`, `"survey"`

Tabela 6. Registos devolvidos pela *string* principal em cada base de dados.

Base de dados	Registos
IEEE Xplore	1442
Scopus	2050
ScienceDirect (duas consultas)	214
Total	**3706**

(CI1–CI3, CE1, CE3, CE4 e CE6); em caso de dúvida, o registo seguia para a fase seguinte. Por limitação de tempo, não houve um segundo revisor independente, pelo que não se calculou a concordância entre revisores; esta limitação é discutida na Secção 8. A triagem deixou 721 estudos elegíveis.

Seleção para análise em profundidade. O número de estudos elegíveis é incompatível com a leitura integral de todos no prazo desta primeira parte do projeto. Adotou-se, por isso, um desvio ao protocolo, que se declara: analisaram-se em texto integral 20 estudos identificados numa fase exploratória, anterior às pesquisas formais. Todos foram devolvidos pelas pesquisas e classificados como elegíveis na triagem, mas não foram escolhidos a partir da lista de elegíveis segundo um critério definido *a priori*. Um deles foi excluído por CI4, por o texto integral não estar acessível, pelo que o conjunto analisado tem 19 estudos. Esta escolha é uma ameaça à validade da síntese, discutida na Secção 8, e a lista completa das decisões de triagem está no repositório.

Leitura integral. Os estudos analisados foram lidos em texto integral, orientando a leitura pelos itens de extração da Secção 3.6; a secção e a página que sustentam cada classificação ficaram registadas no ficheiro de rastreabilidade do repositório.

Snowballing. A revisão de Hintaw et al. [20], citada na comparação de revisões de Lakshminarayana et al. [29, §I], não foi devolvida pelas bases e foi acrescentada às revisões relacionadas por *snowballing* retrospetivo. A Figura 2 resume o processo.

Tabela 7. Critérios de inclusão (CI) e de exclusão (CE).

ID	Critério
CI1	Propõe, implementa ou avalia um mecanismo de segurança para MQTT ou MQTT-SN, ou analisa ameaças específicas do MQTT.
CI2	É um estudo primário com revisão por pares (revista, conferência ou *workshop*).
CI3	Foi publicado entre 2014 e 2026.
CI4	O texto integral está acessível, em inglês ou português.
CE1	O MQTT é apenas usado como transporte, sem contributo de segurança.
CE2	É uma versão preliminar de outro estudo incluído.
CE3	É literatura cinzenta (tese, relatório técnico, patente).
CE4	É uma revisão (analisada à parte, Secção 4).
CE5	Tem menos de quatro páginas ou não descreve o mecanismo com detalhe suficiente.
CE6	Trata só de outro protocolo (CoAP, AMQP, DDS).

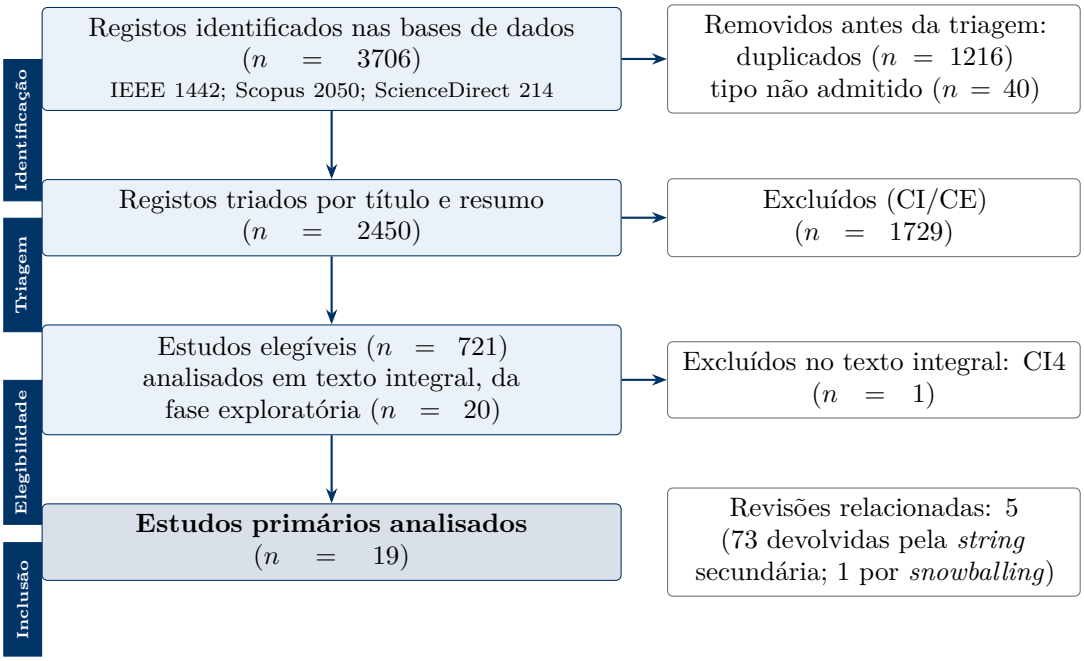


Figura 2. Diagrama de fluxo PRISMA 2020 da seleção dos estudos.

3.6 Extração de dados

Para cada estudo analisado registaram-se os seguintes itens: ano e tipo de publicação (QE1, QE2); tipo de contributo e categoria da taxonomia (QF1, QF2, QE3); ponto de atuação e primitivas usadas (QF2); propriedades garantidas e confiança no *broker* (QF3, QE3); tipo de avaliação e uso de dispositivos restritos (QF4); e limitações declaradas (QF5). O resumo da extração consta do Anexo B.

4 Trabalhos relacionados: revisões existentes

A *string* secundária devolveu 92 registos (73 únicos). Destes, e das revisões excluídas por CE4 na triagem da *string* principal, selecionaram-se as quatro mais diretamente relacionadas com a segurança do MQTT; a quinta, de Hintaw et al., foi acrescentada por *snowballing* (Secção 3.5).

- **Perrone et al. (2017)** [30], escrito após os ataques da botnet Mirai, descreve as soluções de

segurança habitualmente usadas em instalações MQTT reais e fecha com um levantamento de temas de investigação que os próprios autores descrevem como conciso e não exaustivo.

- **Nebbione e Calzarossa (2020)** [31] revêem a segurança dos protocolos da camada de aplicação da IoT, incluindo o MQTT, as vulnerabilidades publicadas (CVE) e boas práticas de mitigação.
- **Hintaw et al. (2023)** [20] organizam os problemas de segurança do MQTT em negação de serviço, falsificação de identidade, divulgação de informação, elevação de privilégios e adulteração, e apontam o custo da segurança em dispositivos a bateria como desafio em aberto.
- **Lakshminarayana et al. (2024)** [29] classificam as vulnerabilidades e os ataques ao MQTT e discutem as defesas, com ênfase na identificação de vulnerabilidades e na deteção de ataques.
- **Laghari et al. (2024)** [32] apresentam uma taxonomia de ataques ao ecossistema MQTT e apontam às revisões anteriores uma discussão ampla mas superficial.

Tabela 8. Comparação das revisões relacionadas com a presente revisão. ✓ abordado; ● parcialmente; – não reportado. *Classificada a partir do resumo: o texto integral não estava acessível.

Revisão	Ano	Só MQTT	Taxonomia de ataques	Revê defesas	Compara por propriedade	Protocolo RSL explícito	Propõe arquitetura
Perrone et al. [30]	2017	✓	–	✓	–	–	–
Nebbione e Calzarossa [31]	2020	●	✓	✓	–	–	–
Hintaw et al. [20]*	2023	✓	●	✓	–	–	–
Lakshminarayana et al. [29]	2024	✓	✓	✓	–	–	–
Laghari et al. [32]	2024	✓	✓	✓	–	●	–
Este trabalho	2026	✓	●	✓	✓	✓	✓

As revisões existentes organizam-se em torno dos *ataques* (Tabela 8). Só Laghari et al. descrevem a pesquisa e a seleção, e apenas das revisões que comparam, com uma única palavra-chave em três fontes [32, §I]. Esta revisão distingue-se por relatar um protocolo explícito e reprodutível, por comparar os estudos segundo as propriedades que garantem à *mensagem* (incluindo validade temporal, anti-repetição e não repúdio) e a confiança que depositam no *broker*, por cobrir trabalhos até 2026 e por ligar as lacunas encontradas a uma proposta concreta.

5 Resultados da revisão

A Tabela 9 identifica os 19 estudos primários analisados em texto integral (Secção 3.5), numerados por ordem cronológica (E01–E19), com o tipo de publicação e a categoria que lhes foi atribuída na taxonomia da Secção 5.2.

5.1 Caracterização dos estudos (QE1, QE2)

Publicações por ano (QE1). A Figura 3 mostra a distribuição temporal dos 721 estudos elegíveis após a triagem. O interesse surge logo após a normalização do MQTT 3.1.1 (2014) e

Tabela 9. Estudos primários incluídos. Tipo: R revista, C conferência, W *workshop*. Categorias: ver Figura 4.

ID	Estudo	Ano	Tipo	Cat.	ID	Estudo	Ano	Tipo	Cat.
E01	Singh et al. [23]	2015	C	C4	E11	Vaccari et al. [22]	2020	R	C7
E02	Niruntasukrat et al. [33]	2016	W	C3	E12	Segarra et al. [6]	2020	C	C6
E03	Rizzardi et al. [34]	2016	R	C3	E13	Dahlmanns et al. [35]	2021	W	C5
E04	Andy et al. [36]	2017	C	C1	E14	Spielvogel et al. [10]	2021	W	C6
E05	Calabretta et al. [28]	2018	R	C3	E15	Prantl et al. [9]	2021	C	C6
E06	Hernández Ramos et al. [37]	2018	R	C1	E16	Van Glabbeek et al. [3]	2022	R	C5
E07	Dinculeană e Cheng [38]	2019	R	C5	E17	Buccafurri et al. [39]	2023	R	C8
E08	Malina et al. [40]	2019	C	C5	E18	Alotaibi et al. [25]	2024	R	C7
E09	Sadio et al. [24]	2019	C	C5	E19	Javadi et al. [41]	2026	R	C2
E10	Vaccari et al. [21]	2020	R	C1					

cresce de forma contínua: os anos de 2023 a 2026 reúnem 410 estudos (56,9 %), e o ano de 2026 está contado só até à data das pesquisas. Destes estudos elegíveis, só 19 foram analisados em texto integral (Secção 3.5); as restantes estatísticas desta secção referem-se a esse conjunto.

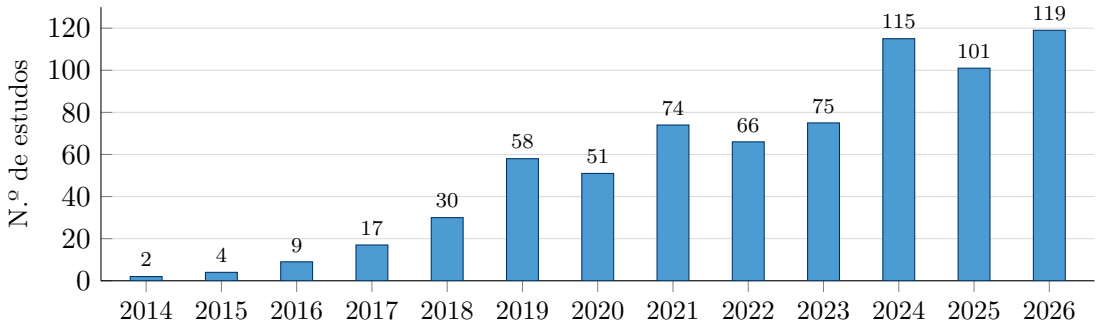


Figura 3. Estudos elegíveis após a triagem, por ano de publicação (n = 721; 2026 até à data das pesquisas). Destes, 19 foram analisados em texto integral.

Tipo de publicação (QE2). Dos 19 estudos analisados, dez (52,6 %) foram publicados em revistas, seis (31,6 %) em conferências e três (15,8 %) em *workshops*.

5.2 Taxonomia das soluções (QF2)

Os estudos foram agrupados em oito categorias segundo o ponto de atuação e o objetivo do seu contributo principal (Figura 4).

5.2.1 C1 — Análise de vulnerabilidades e ataques

Andy et al. [36] mostram que, por omissão, o MQTT não cifra os dados e demonstram ataques à privacidade, à autenticação e à integridade. Hernández Ramos et al. [37] propõem uma técnica de *fuzzing* baseada em *templates* que encontrou falhas novas em implementações reais. Vaccari et al. [21] propõem o SlowITe, um ataque de negação de serviço de baixa taxa, eficaz contra serviços reais com e sem cifra.

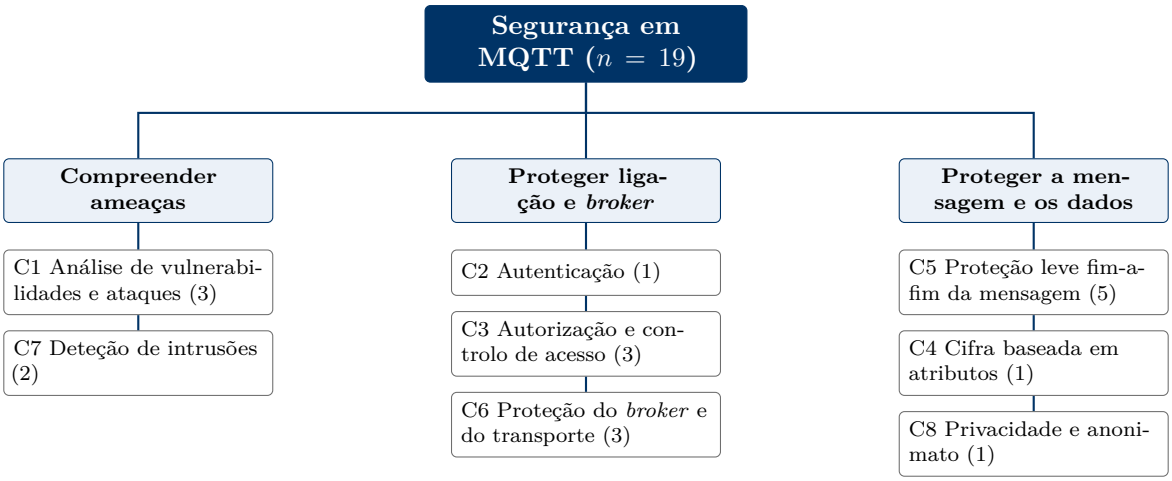


Figura 4. Taxonomia dos estudos incluídos, com o número de estudos por categoria.

5.2.2 C2 — Autenticação

Javadi et al. [41] propõem o CMAP, autenticação mútua sem certificados, sobre curvas elípticas, entre cada dispositivo e o *broker*. A segurança é demonstrada no modelo do oráculo aleatório e o protocolo é avaliado em Raspberry Pi (338 ms de latência de autenticação contra 713 ms com TLS) e em simulação NS-3. A resistência à repetição que reportam diz respeito às mensagens de autenticação, protegidas por *nonces* frescos, e não às mensagens publicadas.

5.2.3 C3 — Autorização e controlo de acesso

Niruntasukrat et al. [33] adaptam o OAuth 1.0a a nós restritos e mostram atrasos de autorização mínimos numa plataforma real. Rizzardi et al. [34] estendem o MQTT com gestão de chaves e aplicação de políticas (AUPS, em código aberto). Calabretta et al. [28] propõem o MQTT-Auth: o AugPAKE garante a confidencialidade e dois *tokens* autenticam e autorizam o acesso a cada tópico.

5.2.4 C4 — Cifra baseada em atributos

Singh et al. [23] propõem o SMQTT e o SMQTT-SN, que acrescentam ao MQTT cifra baseada em atributos com política na chave ou no criptograma (KP/CP-ABE) sobre criptografia de curvas elípticas (ECC) leve, avaliada em simulação: só os subscritores com atributos compatíveis decifram. A ABE resolve a confidencialidade de grupo, mas com um custo computacional elevado para dispositivos restritos.

5.2.5 C5 — Proteção leve fim-a-fim da mensagem

É a categoria mais numerosa. Dinculeană e Cheng [38] enviam valores sob a forma de HMAC (*Value-to-HMAC*), com melhor desempenho do que uma cifra simétrica; os próprios autores remetem para outros mecanismos a autenticação dos clientes, a distribuição de chaves e a proteção contra repetição [38, §6]. Malina et al. [40] propõem três níveis de segurança, do simples controlo de adulteração à autenticação mútua de todas as partes. Todos assinam com Schnorr uma entrada que inclui o nível, o tópico, a identidade do publicador, os dados e um carimbo temporal [40,

§4.5, Eq. 6], o que dá não repúdio e liga a mensagem ao tópico. Nos níveis 2 e 3 o carimbo serve de proteção contra repetição [40, §5.2], mas o *broker* decifra o conteúdo [40, §4.6]. Sadio et al. [24] usam ChaCha20-Poly1305 fim-a-fim, com um protótipo em Arduino UNO. Dahlmanns et al. [35] propõem o ENTRUST: um servidor de chaves distribui, segundo uma ACL, uma chave por tópico aos clientes autorizados, sem alterar o protocolo nem confiar no *broker* [35, §5.2–5.3]. Cada mensagem leva um contador por publicador, que permite detetar duplicados e perdas [35, §5.3]. Van Glabbeek et al. [3] propõem três opções (autenticação e não repúdio; mais confidencialidade; mais anonimato), todas com assinatura Schnorr e carimbo temporal, com um *broker* honesto mas curioso e uma autoridade de certificação (CA) totalmente confiável [3, §3.1, §4.3]. Face ao MQTT sobre TLS, reduzem em 80 % o *overhead* de comunicação e em 40 % o computacional no estabelecimento da ligação.

5.2.6 C6 — Proteção do *broker* e do transporte

Segarra et al. [6] executam o *broker* num ambiente de execução confiável (ARM TrustZone), avaliado com cargas reais de uma aplicação médica. Spielvogel et al. [10] observam que um *broker* reencaminha mensagens independentemente da proteção de cada salto e propõem que publicadores e subscritores possam exigir um nível de segurança mínimo. Prantl et al. [9] medem o impacto do TLS num microcontrolador e concluem que depende sobretudo das condições da rede e da frequência de restabelecimento de ligações.

5.2.7 C7 — Deteção de intrusões

Vaccari et al. [22] publicam o MQTTset, um conjunto de dados de tráfego MQTT legítimo e de ataques para treinar detetores. Alotaibi et al. [25] detetam anomalias em tempo real com um enquadramento distribuído (H2O), com os melhores resultados obtidos por XGBoost.

5.2.8 C8 — Privacidade e anonimato

Buccafurri et al. [39] propõem o MQTT-A, uma rede de *brokers* intermédios que impede o *broker* final de identificar a origem e o destino das mensagens, sem alterar a infraestrutura MQTT.

5.3 Comparação dos mecanismos (QF3, QF4)

A Tabela 10 compara os 16 estudos que propõem mecanismos (C2 a C8); os três estudos de análise (C1) ficam de fora. Cada célula foi classificada a partir do texto integral, e a secção ou página que a sustenta está registada no ficheiro de rastreabilidade do repositório [26]. «Não reportado» (–) não equivale a «ausente por desenho» (✗).

Cobertura das propriedades (QE3). A Figura 5 contabiliza, para os 16 mecanismos, quantos garantem cada propriedade (total ou parcialmente). A confidencialidade é a propriedade mais tratada (12 estudos), seguida da autorização (7), da autenticação (7) e da integridade (7). Só quatro mecanismos funcionam, total ou parcialmente, com um *broker* não confiável. A validade temporal, a proteção contra repetição e o não repúdio são raros, mas não estão ausentes: o ENTRUST deteta duplicados com um contador por publicador [35], e Malina et

Tabela 10. Comparação dos estudos que propõem mecanismos. Propriedades: C confidencialidade, I integridade, Au autenticação, Az autorização, V validade temporal, R anti-repetição, NR não repúdio, D disponibilidade/deteção, P privacidade. BnC: funciona com *broker* não confiável. Aval.: E experimental, F formal, S simulação, A analítica. Restr.: avaliado ou desenhado para dispositivos restritos. ✓ garantido; ● parcialmente; ✗ não, por desenho; – não reportado.

ID	Estudo	Mecanismo principal	C	I	Au	Az	V	R	NR	D	P	BnC	Aval.	Restr.
C2 — Autenticação														
E19	Javadi et al. [41]	Autenticação mútua sem certificados (ECC)	●	●	✓	–	–	–	–	–	–	✗	F, E, S	✓
C3 — Autorização e controlo de acesso														
E02	Niruntasukrat et al. [33]	OAuth 1.0a adaptado	–	–	●	✓	–	–	–	–	–	–	E	✓
E03	Rizzardi et al. [34]	Gestão de chaves e políticas (AUPS)	●	–	–	✓	–	–	–	–	–	–	A, E	✓
E05	Calabretta et al. [28]	AugPAKE e *tokens* por tópico	✓	–	✓	✓	–	–	–	–	–	✗	A, E	✓
C4 — Cifra baseada em atributos														
E01	Singh et al. [23]	KP/CP-ABE sobre ECC	✓	–	–	✓	–	–	–	–	–	✗	S	✓
C5 — Proteção leve fim-a-fim da mensagem														
E07	Dinculeană e Cheng [38]	Mapeamento *Value-to-HMAC*	✓	✓	–	–	–	✗	–	–	–	–	E	✓
E08	Malina et al. [40]	Três níveis de segurança (Schnorr)	●	✓	✓	●	●	●	✓	–	✓	✗	A	✓
E09	Sadio et al. [24]	AEAD ChaCha20-Poly1305	✓	✓	–	–	–	–	–	–	–	✓	E	✓
E13	Dahlmanns et al. [35]	Servidor de chaves por tópico (ENTRUST)	✓	✓	✓	✓	–	✓	–	●	–	✓	E	✓
E16	Van Glabbeek et al. [3]	Três opções com assinatura Schnorr	●	✓	✓	–	●	●	✓	–	✓	●	E	✓
C6 — Proteção do broker e do transporte														
E12	Segarra et al. [6]	*Broker* em TEE (TrustZone)	✓	–	✓	●	–	–	–	–	–	●	E	–
E14	Spielvogel et al. [10]	Nível de segurança exigido por salto	●	–	–	–	–	–	–	–	–	✗	E	–
E15	Prantl et al. [9]	Avaliação do MQTT sobre TLS	✓	✓	–	–	–	–	–	–	–	✗	E	✓
C7 — Deteção de intrusões														
E11	Vaccari et al. [22]	Conjunto de dados para IDS	–	–	–	–	–	–	–	●	–	–	E	–
E18	Alotaibi et al. [25]	IDS distribuído (H2O, XGBoost)	–	–	–	–	–	–	–	●	–	–	E	–
C8 — Privacidade e anonimato														
E17	Buccafurri et al. [39]	Rede de *bridges* anónima	–	–	–	–	–	–	–	–	✓	–	E	–

al. e Van Glabbeek et al. assinam um carimbo temporal, o que dá não repúdio e uma proteção parcial contra repetição [40, 3]. Nenhum dos três combina um limite de idade com a deteção de duplicados dentro desse limite.

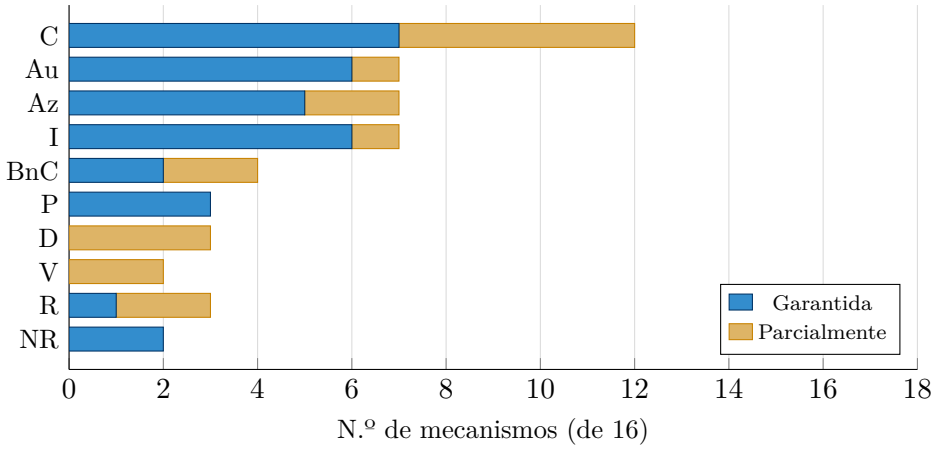


Figura 5. Número de mecanismos que garantem cada propriedade de segurança (siglas como na Tabela 10).

Avaliação (QF4). Catorze dos 16 mecanismos (87,5 %) reportam avaliação experimental; um é avaliado só em simulação [23], um só analiticamente, por contagem de operações [40], e só um apresenta uma prova formal de segurança [41]. Onze são desenhados ou avaliados para dispositivos restritos, do Arduino UNO [24] e do Cortex-M3 [35] ao Raspberry Pi [41]. Nenhum dos estudos analisados mede, no mesmo ensaio, o custo de cada mecanismo e os ataques que ele impede.

5.4 Respostas às perguntas de investigação

QG e QF2. Compreender as ameaças, proteger a ligação e o *broker*, e proteger a mensagem, sendo esta última a frente mais numerosa (Secção 5.2).

QF1. Escuta e injeção quando o MQTT é usado sem cifra, o que acontece por omissão [36], negação de serviço que a cifra não evita [21], erros de implementação [37] e o *broker* como ponto de exposição de todo o conteúdo [6, 35].

QF3 e QE3. Ver a Figura 5: a confidencialidade domina, só quatro mecanismos dispensam a confiança no *broker*, e a validade temporal, a anti-repetição e o não repúdio aparecem isolados em três estudos.

QF4. Sobretudo experimental (14 de 16); uma única prova formal.

QF5. O custo da segurança em dispositivos a bateria [20], a inadequação do TLS a nós restritos [24, 41], a exposição do conteúdo no *broker* [6] e a impossibilidade de um cliente impor a proteção dos restantes saltos [10].

6 Proposta: arquitetura de segurança em camadas

Esta secção propõe uma arquitetura que responde às lacunas identificadas; a sua avaliação experimental é objeto da segunda parte do projeto (Secção 7), na qual a arquitetura será implementada.

6.1 Princípios de desenho

D1. Defesa em profundidade: proteção no transporte, na mensagem e na disponibilidade, de forma independente.

D2. O *broker* não é de confiança para o conteúdo: a confidencialidade, a integridade, a autenticidade, a validade temporal e a não repetição das mensagens não podem depender dele.

D3. Camadas independentes e comutáveis: cada mecanismo é uma camada que pode ser ativada ou desativada sem alterar as restantes, o que permite medir isoladamente o custo e o benefício de cada um.

D4. Verificações baratas primeiro, estado só depois da autenticação: rejeitar cedo o que é barato rejeitar e nunca deixar entrada não autenticada alterar estado.

D5. Estado limitado: toda a estrutura que um atacante consiga fazer crescer tem um limite superior.

6.2 Arquitetura em camadas

Cada extremo (sensor, *gateway*) passa as mensagens por uma sequência ordenada de camadas entre a aplicação e o transporte MQTT (Figura 6): à saída de cima para baixo, à entrada de baixo para cima. A primeira camada que rejeita uma mensagem recebida interrompe o processamento, e a mensagem nunca chega à aplicação. A ordem tem significado: a limitação de tráfego fica junto ao transporte para descartar inundações antes de qualquer operação criptográfica.

6.3 Camada de transporte e *broker*

A primeira camada usa o que os *brokers* já oferecem (Tabela 1), configurado de forma restritiva: só TLS 1.3; autenticação mútua por certificado; palavras-passe; ACL de negação por omissão, parametrizadas pelo utilizador autenticado; identificador de cliente ligado ao utilizador; e limites de tamanho de pacote e de ligações. Esta camada restringe quem fala com o *broker*, mas deixa intactos os problemas P1 a P3.

6.4 Envelope fim-a-fim

A camada de segurança substitui o conteúdo de cada mensagem por um *envelope*: um cabeçalho fixo de 25 octetos (identificador do formato, versão, modo, identificador de chave, número de sequência, instante em milissegundos e comprimento do *nonce*), seguido do *nonce* e do corpo.

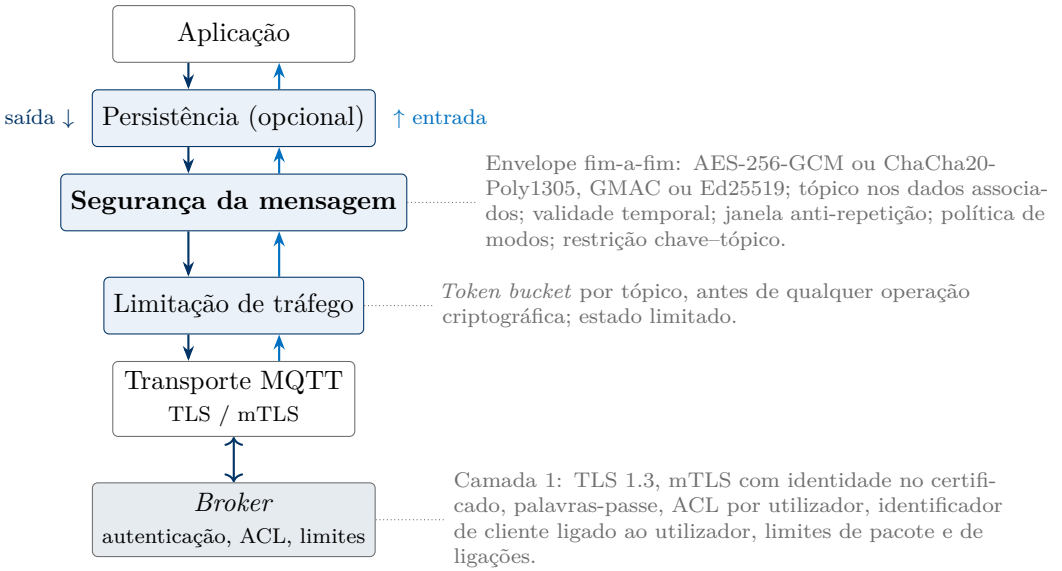


Figura 6. Arquitetura proposta: camadas entre a aplicação e o transporte, cada uma comutável de forma independente. A saída percorre as camadas de cima para baixo e a entrada de baixo para cima.

Dados associados e ligação ao tópico. Sendo *cab* o cabeçalho, N o *nonce* e τ o tópico MQTT, os dados associados são

$$A = cab \,\|\, N \,\|\, \mathrm{u16}(|\tau|) \,\|\, \tau. \tag{5}$$

Como o tópico entra na autenticação mas não no envelope, uma mensagem válida republicada noutro tópico falha a verificação, e nenhum campo do cabeçalho pode ser alterado.

Modos de proteção. O remetente escolhe um de três modos, indicado no cabeçalho:

$$\textbf{cifra:} \quad corpo = C \,\|\, T, \qquad (C, T) = \text{AES-GCM.Enc}(K, N, P, A); \tag{6}$$

$$\textbf{autenticação:} \quad corpo = P \,\|\, T, \qquad T = \text{AES-GCM.Enc}(K, N, \varnothing, A \,\|\, P); \tag{7}$$

$$\textbf{assinatura:} \quad corpo = P \,\|\, \sigma, \qquad \sigma = \text{Ed25519.Sign}(sk, A \,\|\, P),\ \ N = \varnothing. \tag{8}$$

O modo de cifra garante confidencialidade e integridade; o de autenticação (GMAC) garante integridade com o conteúdo legível; o de assinatura acrescenta prova de origem, porque o recetor só guarda chaves públicas. Nos modos de cifra e de autenticação, o AES-256-GCM poderá ser substituído pelo ChaCha20-Poly1305 [13, §2.8], a alternativa para processadores sem AES em *hardware*. O algoritmo será um atributo da chave identificada no cabeçalho, que é autenticado, pelo que o formato do envelope não muda: ambos usam *nonces* de 96 bits e etiquetas de 128 bits [13, §2.5, §2.8]. O custo fixo por mensagem é de 53 octetos nos modos de cifra e de autenticação (cabeçalho, *nonce* de 12 e etiqueta de 16) e de 89 no modo de assinatura (cabeçalho e assinatura de 64).

Política do recetor contra a redução do nível de proteção. Cada recetor mantém o conjunto $\mathcal{A} \subseteq \{\text{cifra}, \text{autenticação}, \text{assinatura}\}$ dos modos que aceita e rejeita qualquer envelope cujo modo $\mu \notin \mathcal{A}$. Como μ faz parte de A, não pode ser alterado sem invalidar a etiqueta.

6.5 Ordem de verificação no recetor

A Tabela 11 define a sequência de verificações, que decorre do princípio D4.

Tabela 11. Sequência de verificações de um envelope recebido.

#	Verificação	Justificação da posição	Rejeição
1	Formato do envelope	Descarta conteúdo não protegido (por exemplo, injeções em claro)	mensagem malformada
2	Modo $\mu \in \mathcal{A}$	Barato; o modo está em A, pelo que mentir sobre ele só pode falhar	modo não aceite
3	Validade temporal, Eq. (2)	Barato; o instante está em A, pelo que alterá-lo invalida a etiqueta	mensagem expirada
4	Chave conhecida e verificação criptográfica	A partir daqui a mensagem é autêntica; a falha é sempre a mesma, sem revelar a causa (sem oráculo)	falha de autenticação
5	Restrição chave–tópico, Eq. (9)	Só depois da autenticação: entrada não autenticada não pode sondar a política	permissão negada
6	Janela anti-repetição, Eq. (3)	Só depois da autenticação (números forjados não avançam a janela) e da restrição (uma mensagem recusada não consome o seu número)	repetição detetada

6.6 Validade temporal e anti-repetição

Usa-se a Eq. (2) com $\Delta_a = 60$ s e $\Delta_s = 5$ s como valores por omissão, que deverão ser ajustáveis por fluxo (uma ordem a um atuador pode exigir uma validade mais curta do que uma leitura de telemetria), e a janela da Eq. (3) com $w = 64$, por identificador de chave. Os dois mecanismos são complementares: a validade temporal sozinha deixa passar repetições com menos de Δ_a; a janela sozinha perde o estado num reinício do recetor, caso em que a validade temporal limita a exposição a Δ_a. O número de janelas é limitado (princípio D5), e os limites do GCM e do espaço de sequências impõem a rotação das chaves. Um duplicado legítimo do QoS 1 é rejeitado pela janela como qualquer repetição, o que é o comportamento pretendido: a camada MQTT confirma-o, mas a aplicação não volta a executar a ação. A marca `DUP` do MQTT não é usada, por não ser autenticada [1, §3.3.1.1].

6.7 Restrição chave–tópico

Autenticar uma mensagem prova apenas que foi produzida com a chave k. Para que um dispositivo comprometido não publique, com a sua chave válida, nos tópicos dos outros (problema P3), cada chave tem um dono $\mathrm{dono}(k)$ e o recetor aplica regras de negação por omissão. Sendo F_k as regras específicas da chave, F_* os padrões gerais e σ_k a substituição $\{\texttt{\%u} \mapsto \mathrm{dono}(k),\ \texttt{\%k} \mapsto k\}$:

$$\mathrm{autorizada}(k, \tau) \iff \exists f \in F_k \cup \sigma_k(F_*) :\ \mathrm{corr}(f, \tau), \tag{9}$$

com corr como na Secção 2.1. Por exemplo, com o padrão `+/sensors/%u/#`, a chave de `sensor-7` só pode publicar em `open/sensors/sensor-7/...` e `restricted/sensors/sensor-7/...`.

6.8 Gestão de chaves

Cada dispositivo tem, por época, uma chave AEAD e um par de chaves Ed25519, com um identificador que nunca é reutilizado, porque um identificador reutilizado teria uma janela anti-repetição nova. O *gateway* conhece as chaves AEAD e as chaves públicas de todos os dispositivos, mas só a sua chave privada; cada dispositivo conhece as suas chaves e, do *gateway*, a chave AEAD (usada nas ordens) e a chave pública.

A **rotação** instala as chaves da época $e+1$ ao lado das da época e e revoga as antigas após um período de graça; a **revogação** de um dispositivo remove as suas chaves, a sua palavra-passe e o seu certificado.

6.9 Limitação de tráfego antes da criptografia

Junto ao transporte, uma camada aplica a Eq. (4) por tópico, rejeitando o excesso antes de qualquer verificação criptográfica. O número de baldes é limitado; acima do limite, os tópicos novos partilham um único balde, pelo que um atacante não ganha orçamento inventando tópicos.

Esta limitação no recetor e os limites do *broker* da primeira camada (tamanho de pacote e número de ligações) protegem pontos de esgotamento diferentes. A do recetor contém o trabalho criptográfico do *gateway* sob inundação de mensagens, mas atua só depois de o *broker* ter recebido e reencaminhado o tráfego. Um ataque como o SlowITe, que esgota as ligações disponíveis no próprio *broker* [21], só pode ser contido no *broker*. Nenhuma das duas dá uma garantia geral contra a negação de serviço, e ambas podem descartar tráfego legítimo, o que o plano de avaliação mede.

6.10 Comparação com os trabalhos relacionados

A Tabela 12 compara a proposta com os trabalhos mais próximos, acrescentando três mecanismos: ligação ao tópico (LT), política contra a redução do nível de proteção (RN) e restrição chave–tópico (CT).

Tabela 12. Posicionamento da proposta face aos trabalhos relacionados mais próximos. Siglas e símbolos como na Tabela 10; LT ligação ao tópico; RN política contra a redução do nível de proteção; CT restrição chave–tópico; Com.: camadas comutáveis em tempo de execução.

ID	Trabalho	C	I	Au	Az	V	R	NR	D	P	BnC	LT	RN	CT	Com.
E01	Singh et al. [23]	✓	–	–	✓	–	–	–	–	–	✗	–	–	–	–
E05	Calabretta et al. [28]	✓	–	✓	✓	–	–	–	–	–	✗	●	–	–	–
E07	Dinculeană e Cheng [38]	✓	✓	–	–	–	✗	–	–	–	–	–	–	–	–
E08	Malina et al. [40]	●	✓	✓	●	●	●	✓	–	✓	✗	✓	●	–	●
E09	Sadio et al. [24]	✓	✓	–	–	–	–	–	–	–	✓	–	–	–	–
E12	Segarra et al. [6]	✓	–	✓	●	–	–	–	–	–	●	–	–	–	–
E13	Dahlmanns et al. [35]	✓	✓	✓	✓	–	✓	–	●	–	✓	●	–	●	–
E16	Van Glabbeek et al. [3]	●	✓	✓	–	●	●	✓	–	✓	●	–	–	–	●
E19	Javadi et al. [41]	●	●	✓	–	–	–	–	–	–	✗	–	–	–	–
—	**Proposta**	✓	✓	✓	✓	✓	✓	✓	●	✗	✓	✓	✓	✓	✓

A proposta não supera os trabalhos relacionados em tudo: não oferece anonimato [39], não

protege o *broker* com um TEE [6], não oferece confidencialidade por atributos [23] e não tem prova formal [41]. O que a distingue é combinar, no mesmo recetor e sem confiar no *broker*, propriedades que a literatura trata isoladas (Secção 8).

6.11 Limitações conhecidas

- **Chaves pré-partilhadas**: a distribuição inicial assume um canal seguro; um acordo de chaves por dispositivo (por exemplo, ECDH) eliminá-las-ia.
- **Chave de grupo nas ordens**: nos modos AES, um atuador comprometido pode forjar ordens para os outros; o modo de assinatura resolve-o.
- **Estado da janela não persistente**: após um reinício, a proteção contra repetição fica limitada à validade temporal. A segunda parte estudará persistir a janela ou iniciar uma nova época de chaves antes de retomar o fluxo, para que um reinício nunca reponha silenciosamente uma janela vazia.
- **Dados falsos mas autênticos**: um dispositivo comprometido continua a publicar dados falsos nos seus próprios tópicos; só a deteção e a revogação o travam.

7 Objetivo e plano da segunda parte do projeto

O objetivo da segunda parte é **medir, num Raspberry Pi, quanto custa cada camada em desempenho e quanto protege, isoladamente e em combinação, para identificar a configuração com a maior proteção e o menor impacto no desempenho.** Responde à lacuna L5 (Secção 8). Para isso, a segunda parte vai implementar a arquitetura da Secção 6, com cada camada ativável de forma independente, e duas ferramentas de medição: *microbenchmarks* das camadas e um laboratório de carga com *broker*, *gateway*, sensores simulados e um atacante.

7.1 Perguntas experimentais

QP1. Qual é o custo de cada camada num Raspberry Pi (processador, latência, débito, memória, octetos)?

QP2. Que ataques impede cada camada, e quais só a combinação de camadas impede?

QP3. Como varia o custo com o tamanho da mensagem e a carga, e quando satura o Raspberry Pi?

QP4. Quanto pesa a aceleração criptográfica por *hardware*?

QP5. Que configurações são ótimas de Pareto, e qual recomendar para cada caso de uso?

7.2 Configurações em estudo

As configurações da Tabela 13 acrescentam um mecanismo de cada vez, para atribuir a cada passo o seu custo e benefício marginais; K10 isola o contributo do TLS quando o envelope já está ativo, e K11 repete K8 com ChaCha20-Poly1305, para comparar os dois algoritmos com e

sem aceleração AES. O laboratório de carga a desenvolver deverá executar esta matriz de forma automática.

Tabela 13. Configurações a avaliar. Transporte: TLS 1.3 com autenticação mútua por certificado, palavras-passe, ACL e identificador de cliente ligado ao utilizador. VT validade temporal; R anti-repetição; CT restrição chave–tópico; LT limitação de tráfego antes da criptografia.

ID	Transporte	Envelope	VT	R	CT	LT	O que acrescenta
K0	—	—	—	—	—	—	referência, sem proteção
K1	✓	—	—	—	—	—	proteção de cada salto; quem fala com o *broker*
K2	✓	GMAC	—	—	—	—	integridade fim-a-fim e ligação ao tópico
K3	✓	AES-GCM	—	—	—	—	+ confidencialidade face ao *broker*
K4	✓	AES-GCM	✓	—	—	—	+ rejeição de mensagens antigas
K5	✓	AES-GCM	—	✓	—	—	+ rejeição de repetições
K6	✓	AES-GCM	✓	✓	—	—	envelope completo
K7	✓	AES-GCM	✓	✓	✓	—	+ contenção de um dispositivo comprometido
K8	✓	AES-GCM	✓	✓	✓	✓	+ proteção contra inundação
K9	✓	Ed25519	✓	✓	✓	✓	+ não repúdio (prova de origem)
K10	—	AES-GCM	✓	✓	✓	—	envelope completo sem TLS
K11	✓	ChaCha20	✓	✓	✓	✓	K8 com ChaCha20-Poly1305

7.3 Plataforma experimental

Os *microbenchmarks* medirão o custo de cada camada num Raspberry Pi 5, sem rede, para mensagens de 16 B a 64 KiB, também com a aceleração AES desativada (`OPENSSL_armcap=0`), porque muitos dispositivos IoT não a têm [24]; nesse caso medir-se-á também o ChaCha20-Poly1305 (K11). O laboratório de carga acrescentará o TLS, o *broker*, a rede e os ataques: o *broker* e o *gateway* no Raspberry Pi, os sensores e o atacante noutras máquinas da rede local. Ambos serão repetidos num computador de secretária como referência.

7.4 Métricas

O conjunto de ataques $\mathcal{A}$, a executar pelo atacante do laboratório, cobre as ameaças da Tabela 2: escuta, injeção, adulteração, repetição, republicação noutro tópico, usurpação de identidade, publicação com a chave de outro dispositivo, redução do nível de proteção e inundação. A Tabela 15 indica, para cada ataque, a camada que o deverá impedir e o que é preciso observar para atribuir a rejeição a essa camada. São expectativas do desenho, a confirmar ou refutar nos ensaios.

7.5 Critério de escolha da melhor configuração

Proteção. A proteção de uma configuração c é a fração ponderada dos ataques que impede,

$$S(c) = \frac{\sum_{a \in \mathcal{A}} w_a \, b_a(c)}{\sum_{a \in \mathcal{A}} w_a}, \qquad 0 \le S(c) \le 1, \tag{10}$$

Tabela 14. Métricas de custo e de benefício.

Métrica	Definição	Nível
Custo		
Processador por mensagem	µs de CPU por mensagem (envio e receção)	1, 2
Latência	p50 e p99, do envio pelo sensor à entrega à aplicação	2
Débito máximo sustentado	maior taxa com perda $< 1\,\%$ e p99 dentro do limite	2
Octetos acrescentados	octetos na rede menos o conteúdo; teoricamente 53 ou 89 (Secção 6.4)	1
Memória	pico de memória residente do *gateway* e do *broker*	2
Estabelecimento de ligação	tempo de ligação (TLS e CONNECT) e custo das religações	2
Energia (opcional)	consumo do Raspberry Pi, com medidor USB	2
Benefício		
Ataques impedidos	para cada ataque $a \in \mathcal{A}$, $b_a(c) = 1$ se a configuração c o impede	1, 2
Fuga de informação	fração das mensagens legítimas legível por um subscritor de `#`	1, 2

com pesos $w_a = 1$ por omissão.

Custo. Cada métrica de custo m é normalizada pela configuração de referência e agregada com pesos v_m que somam 1:

$$C(c) = \sum_m v_m \, \frac{m(c)}{m(\mathrm{K0})}, \tag{11}$$

com maior peso para o processador por mensagem e a latência p99, os recursos escassos num dispositivo restrito.

Exequibilidade. Uma configuração só é candidata se, no Raspberry Pi, sustentar a taxa pretendida R_{alvo} com latência $p99 \leq L_{\max}$. Estes limites dependem do cenário de aplicação e serão fixados antes de executar a matriz, para não serem influenciados pelos resultados.

Requisitos por caso de uso. Antes de comparar custos, cada caso de uso fixa as propriedades obrigatórias, e uma configuração que não as cumpra é excluída, qualquer que seja o seu custo; a falta de uma propriedade obrigatória não é compensada por bons resultados noutra. Consideram-se três casos:

- **Telemetria de conteúdo não sensível**: integridade, ligação ao tópico e anti-repetição obrigatórias; a confidencialidade perante o *broker* é dispensável, pelo que o modo de autenticação é admissível.
- **Telemetria sensível**: a confidencialidade perante o *broker* é obrigatória, pelo que só o modo de cifra é admissível; o modo de assinatura sozinho fica excluído, porque deixa o conteúdo legível.
- **Ordens a atuadores**: validade temporal, anti-repetição e restrição chave–tópico obrigatórias; quando o recetor não puder forjar ordens em nome do emissor, só o modo de assinatura é admissível. Se as ordens exigirem também confidencialidade, nenhum dos três modos atuais cumpre ambos os requisitos, o que fica registado como limitação e como possível extensão (cifra seguida de assinatura).

Tabela 15. Ataques a ensaiar, proteção esperada e observação necessária. Todos os ensaios decorrem com tráfego legítimo ativo.

Ataque	Proteção esperada	Observação necessária
Escuta na rede e no *broker*	TLS protege cada salto; perante o *broker*, só o modo de cifra oculta o conteúdo	Separar o ponto de captura; tópico, tamanho e frequência continuam visíveis
Injeção e adulteração	O envelope rejeita etiquetas e assinaturas inválidas; a ACL restringe quem publica num *broker* legítimo	Mensagens aceites indevidamente e ações executadas na aplicação
Republicação noutro tópico	O tópico está nos dados associados (Eq. (5))	Copiar o mesmo envelope para outro tópico, sem o recriar
Publicação noutro tópico com chave válida	Restrição chave–tópico no recetor; ACL num *broker* legítimo	Repetir com um *broker* ativo, para separar o contributo da ACL e o da restrição
Repetição dentro da validade	Janela anti-repetição; a validade temporal sozinha não chega	Repetir uma mensagem recente e contar ações; verificar a reordenação admissível
Mensagem antiga nunca recebida	Validade temporal; a janela sozinha pode aceitá-la	Ensaiar a idade e a sequência em separado
Redução do nível de proteção	Modo nos dados associados e política do recetor	Alterar o modo sem a chave; usar um modo válido mas não aceite
Falsificação pelo recetor	Só o modo de assinatura a impede; nos modos AES o recetor tem a chave	Dar ao atacante o material de verificação do recetor
Usurpação de identidade	mTLS, palavras-passe e identificador de cliente ligado ao utilizador	Ligar com a credencial ou o identificador de outro cliente
Inundação de mensagens	Limitação de tráfego no recetor	Processador do *gateway*, latência e entrega útil, também com o tópico da vítima
Ocupação de ligações [21]	Limites de ligações no *broker*	Ligações legítimas admitidas e tempo de recuperação

Para cada caso, o critério seguinte aplica-se apenas às configurações que cumprem os requisitos obrigatórios.

Escolha. A configuração c domina c' se $S(c) \geq S(c')$ e $C(c) \leq C(c')$, com pelo menos uma desigualdade estrita. As configurações exequíveis não dominadas formam a *fronteira de Pareto* $\mathcal{P}$, e a configuração recomendada é a mais barata entre as que atingem a proteção máxima:

$$c^* = \operatorname*{arg\,min}_{c \in \mathcal{P},\ S(c)=S_{\max}} C(c). \tag{12}$$

Reporta-se também o custo marginal $\Delta C/\Delta S$ de cada passo ao longo da fronteira.

7.6 Procedimento e hipóteses

Cada configuração será repetida 10 vezes em ordem aleatória, com intervalos de confiança por *bootstrap* sobre as execuções. O custo marginal de uma camada ℓ numa métrica m é $m(c_{\ell=1}) - m(c_{\ell=0})$, com os restantes fatores fixos, e a diferença das diferenças mostra se pares de camadas interagem. Os ataques correrão com tráfego legítimo ativo e com controlos negativos (a mesma configuração sem a camada em causa), para atribuir cada rejeição à camada certa.

H1. O envelope AES-256-GCM terá um custo por mensagem pequeno face à latência da rede.

H2. A validade temporal, a anti-repetição e a restrição chave–tópico terão custo marginal quase nulo: aumentam S quase sem aumentar C.

H3. As assinaturas Ed25519 custarão claramente mais do que o AES-GCM por mensagem, pelo que só se justificarão onde a prova de origem for necessária.

H4. O custo do TLS concentrar-se-á no estabelecimento da ligação, como observado em [9].

H5. Sob inundação, a limitação de tráfego antes da criptografia (K8) reduzirá o processador gasto pelo *gateway*.

Se as hipóteses se confirmarem, a configuração recomendada será K8 (ou K11, em processadores sem AES em *hardware*) para a telemetria, com K9 reservada às ordens que exigem prova de origem. É precisamente isso que a segunda parte pretende verificar.

8 Discussão

8.1 Lacunas do estado da arte

A comparação dos 19 estudos analisados evidencia cinco lacunas. São lacunas *nos estudos analisados*: os estudos analisados vêm de uma fase exploratória e não de um critério de seleção definido *a priori* (Secção 3.5), pelo que não se afirma que nenhum dos restantes estudos elegíveis as resolva.

L1. A frescura e a deteção de duplicados não aparecem combinadas. Malina et al. e Van Glabbeek et al. assinam um carimbo temporal e apresentam-no como proteção contra repetição, mas não definem a janela de aceitação nem eliminam duplicados dentro dela [40, §5.2], [3, §3.4]. O ENTRUST deteta duplicados com um contador por publicador, mas o seu campo temporal indica quando chega a próxima mensagem, e não a idade máxima de cada mensagem [35, §5.3, §6].

L2. A ligação da mensagem ao contexto é incompleta. Malina et al. assinam o tópico e o nível de segurança [40, §4.5], e o ENTRUST usa uma chave por tópico [35, §5]. Nenhum dos estudos analisados aplica, no recetor, uma restrição entre a credencial autenticada e os tópicos em que pode publicar, nem uma política local que recuse níveis de proteção mais fracos.

L3. O *broker* continua, em regra, a ser de confiança. Só quatro dos 16 mecanismos dispensam, total ou parcialmente, essa confiança, e vários assumem-na explicitamente [23, §III-B], [28, §IV-A], [40, §4.6].

L4. O não repúdio é raro e depende de terceiros confiáveis. Só Malina et al. e Van Glabbeek et al. o oferecem, com um *broker* que decifra ou é honesto mas curioso e, no segundo caso, uma CA totalmente confiável [3, §3.1]. As restantes soluções usam segredos partilhados, pelo que quem os detém, incluindo o recetor, pode forjar mensagens em nome do remetente.

L5. Custo e benefício não são medidos em conjunto. As avaliações medem o custo, mas não o relacionam, no mesmo ensaio, com os ataques impedidos, e usam plataformas e métricas que não são comparáveis entre si.

Nenhuma destas lacunas pede um mecanismo criptográfico novo: os elementos existem, isolados, na literatura. A arquitetura proposta responde a L1, L2 e L4 combinando-os no mesmo recetor e sem confiar no *broker* (L3), e o desenho em camadas comutáveis foi pensado para que a segunda parte do projeto responda a L5 (Secção 7).

8.2 Ameaças à validade

A Tabela 16 resume as ameaças à validade da revisão, seguindo Kitchenham e Charters [7].

Tabela 16. Ameaças à validade da revisão e mitigação.

Tipo	Ameaça	Mitigação
Construção	A *string* pode não captar estudos que usem outra terminologia	Grupos de sinónimos; refinamento após a leitura das revisões; inclusão de MQTT-SN e de termos de deteção; os estudos já conhecidos foram todos devolvidos pelas pesquisas
Seleção	Enviesamento na aplicação dos critérios na triagem, feita por um só revisor, sem medida de concordância	Critérios operacionalizados com exemplos; regra conservadora (na dúvida, o registo segue); decisão e critério de cada registo publicados no repositório, para verificação independente
Síntese	Só 19 dos 721 estudos elegíveis foram analisados em texto integral, identificados numa fase exploratória e não escolhidos por um critério *a priori*; as lacunas podem estar tratadas em estudos não analisados	Desvio declarado; todos confirmados como elegíveis; lacunas formuladas «nos estudos analisados»; lista completa da triagem no repositório [26]
Extração	Subjetividade na classificação das propriedades; um estudo pode garantir uma propriedade sem a descrever	Leitura do texto integral; «não reportado» distinto de «ausente por desenho»; secção e página de cada célula registadas no repositório
Externa	Só três bases de dados; ACM DL e Web of Science não pesquisadas; enviesamento de publicação	O Scopus indexa as atas ACM relevantes (p. ex. ARES, SaT-CPS, ICPE); inglês e português; revista, conferência e *workshop*
Conclusão	Os números por propriedade dependem da granularidade das categorias	Taxonomia e critérios publicados; dados de extração no Anexo B

A ameaça mais relevante é a da síntese: com 721 estudos elegíveis e 19 analisados, as percentagens da Secção 5 descrevem o conjunto analisado, e não todo o campo. Na extração, a leitura integral alterou várias células face à leitura dos resumos (por exemplo, o contador anti-repetição do ENTRUST e o não repúdio de Malina et al.), o que confirma que «não reportado no resumo» não deve ser lido como «ausente».

9 Conclusões e trabalho futuro

Este trabalho apresentou uma revisão sistemática da literatura sobre segurança em comunicações IoT baseadas em MQTT, com 2450 registos triados e 19 estudos primários (2015–2026) e 5 revisões relacionadas analisados em texto integral. As principais conclusões são:

- O TLS, por terminar no *broker*, não protege as mensagens de um *broker* comprometido nem de clientes com acesso legítimo.
- A proteção leve fim-a-fim é a categoria mais numerosa, e a confidencialidade, a autenticação e a integridade são as propriedades mais tratadas.
- A validade temporal, a deteção de duplicados, a ligação ao tópico e o não repúdio aparecem em poucos estudos e nunca combinados; a restrição chave–tópico no recetor e a política contra a redução do nível de proteção não aparecem nos estudos analisados; e a maioria das soluções confia no *broker*.
- As avaliações medem o custo dos mecanismos, mas não o relacionam com os ataques impedidos.

Com base nestas lacunas, propôs-se, não um mecanismo novo, mas a integração destes elementos numa arquitetura em camadas independentes e comutáveis, com defesa no transporte, um envelope fim-a-fim (AES-256-GCM ou ChaCha20-Poly1305, GMAC ou Ed25519, com tópico e cabeçalho nos dados associados, validade temporal, anti-repetição, política de modos e restrição chave–tópico) e limitação de tráfego antes da criptografia.

Como trabalho futuro, fica sobretudo a segunda parte do projeto (Secção 7): medir num Raspberry Pi o custo e os ataques impedidos por cada configuração e escolher a melhor pela fronteira de Pareto. Seguem-se a análise em texto integral dos restantes estudos elegíveis, a verificação formal do envelope, à semelhança de [41], um acordo de chaves por dispositivo e a integração com deteção de intrusões [22, 25].

Referências

[1] A. Banks and R. Gupta, "MQTT version 3.1.1," OASIS, OASIS Standard, Oct. 2014. [Online]. Available: https://docs.oasis-open.org/mqtt/mqtt/v3.1.1/os/mqtt-v3.1.1-os.html

[2] A. Banks, E. Briggs, K. Borgendale, and R. Gupta, "MQTT version 5.0," OASIS, OASIS Standard, Mar. 2019. [Online]. Available: https://docs.oasis-open.org/mqtt/mqtt/v5.0/os/mqtt-v5.0-os.html

[3] R. Van Glabbeek, D. Deac, T. Perale, K. Steenhaut, and A. Braeken, "Flexible and efficient security framework for many-to-many communication in a publish/subscribe architecture," *Sensors*, vol. 22, no. 19, p. 7391, 2022.

[4] R. A. Light, "Mosquitto: Server and client implementation of the MQTT protocol," *The Journal of Open Source Software*, vol. 2, no. 13, p. 265, 2017.

[5] E. Rescorla, "The transport layer security (TLS) protocol version 1.3," RFC 8446, IETF, Aug. 2018.

[6] C. Segarra, R. Delgado-Gonzalo, and V. Schiavoni, "MQT-TZ: Hardening IoT brokers using ARM TrustZone (practical experience report)," in *Proc. Int. Symp. Reliable Distributed Systems (SRDS)*, 2020, pp. 256–265.

[7] B. Kitchenham and S. Charters, "Guidelines for performing systematic literature reviews in software engineering," Keele University and Durham University, Technical Report EBSE-2007-01, version 2.3, 2007.

[8] M. J. Page, J. E. McKenzie, P. M. Bossuyt, I. Boutron, T. C. Hoffmann, C. D. Mulrow, L. Shamseer, J. M. Tetzlaff, E. A. Akl, S. E. Brennan *et al.*, "The PRISMA 2020 statement: An updated guideline for reporting systematic reviews," *BMJ*, vol. 372, p. n71, 2021.

[9] T. Prantl, L. Iffländer, S. Herrnleben, S. Engel, S. Kounev, and C. Krupitzer, "Performance impact analysis of securing MQTT using TLS," in *Proc. ACM/SPEC Int. Conf. Performance Engineering (ICPE)*, 2021, pp. 241–248.

[10] K. Spielvogel, H. C. Pöhls, and J. Posegga, "TLS beyond the broker: Enforcing fine-grained security and trust in publish/subscribe environments for IoT," in *Security and Trust Management (STM 2021)*, ser. Lecture Notes in Computer Science. Springer, 2021, pp. 145–162.

[11] M. J. Dworkin, "Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC," National Institute of Standards and Technology, NIST Special Publication 800-38D, 2007.

[12] H. Böck, A. Zauner, S. Devlin, J. Somorovsky, and P. Jovanovic, "Nonce-disrespecting adversaries: Practical forgery attacks on GCM in TLS," in *Proc. 10th USENIX Workshop on Offensive Technologies (WOOT 16)*. Austin, TX, USA: USENIX Association, 2016. [Online]. Available: https://www.usenix.org/conference/woot16/workshop-program/presentation/bock

[13] Y. Nir and A. Langley, "ChaCha20 and Poly1305 for IETF protocols," RFC 8439, IETF, Jun. 2018.

[14] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-hashing for message authentication," RFC 2104, IETF, Feb. 1997.

[15] D. J. Bernstein, N. Duif, T. Lange, P. Schwabe, and B.-Y. Yang, "High-speed high-security signatures," *Journal of Cryptographic Engineering*, vol. 2, no. 2, pp. 77–89, 2012.

[16] S. Josefsson and I. Liusvaara, "Edwards-curve digital signature algorithm (EdDSA)," RFC 8032, IETF, Jan. 2017.

[17] S. Kent, "IP encapsulating security payload (ESP)," RFC 4303, IETF, Dec. 2005.

[18] J. Heinanen and R. Guerin, "A single rate three color marker," RFC 2697, IETF, Sep. 1999.

[19] L. Kohnfelder and P. Garg, "The threats to our products," Microsoft Interface, 1 de abril de 1999. Arquivado em https://web.archive.org/web/20140424003912/http://blogs.msdn.com/cfs-filesystemfile.ashx/___key/communityserver-components-postattachments/00-09-88-74-86/The-threats-to-our-products.docx, 1999.

[20] A. J. Hintaw, S. Manickam, M. F. Aboalmaaly, and S. Karuppayah, "MQTT vulnerabilities, attack vectors and solutions in the Internet of Things (IoT)," *IETE Journal of Research*, vol. 69, no. 6, pp. 3368–3397, 2023.

[21] I. Vaccari, M. Aiello, and E. Cambiaso, "SlowITe, a novel denial of service attack affecting MQTT," *Sensors*, vol. 20, no. 10, p. 2932, 2020.

[22] I. Vaccari, G. Chiola, M. Aiello, M. Mongelli, and E. Cambiaso, "MQTTset, a new dataset for machine learning techniques on MQTT," *Sensors*, vol. 20, no. 22, p. 6578, 2020.

[23] M. Singh, M. A. Rajan, V. L. Shivraj, and P. Balamuralidhar, "Secure MQTT for Internet of Things (IoT)," in *Proc. 5th Int. Conf. Communication Systems and Network Technologies (CSNT)*, 2015, pp. 746–751.

[24] O. Sadio, I. Ngom, and C. Lishou, "Lightweight security scheme for MQTT/MQTT-SN protocol," in *Proc. 6th Int. Conf. Internet of Things: Systems, Management and Security (IOTSMS)*, 2019, pp. 119–123.

[25] N. S. Alotaibi, H. I. S. Ahmed, S. O. M. Kamel, and G. F. ElKabbany, "Secure enhancement for MQTT protocol using distributed machine learning framework," *Sensors*, vol. 24, no. 5, p. 1638, 2024.

[26] Autores do projeto, "mqtt-secure: Arquitetura de segurança em camadas para comunicações IoT baseadas em MQTT," Repositório GitHub, 2026. [Online]. Available: https://github.com/joaoaeafonso/mqtt_secure

[27] M. Calabretta, R. Pecori, and L. Veltri, "A token-based protocol for securing MQTT communications," in *Proc. 26th Int. Conf. Software, Telecommunications and Computer Networks (SoftCOM)*, 2018, pp. 1–6.

[28] M. Calabretta, R. Pecori, M. Vecchio, and L. Veltri, "MQTT-Auth: A token-based solution to endow MQTT with authentication and authorization capabilities," *Journal of Communications Software and Systems*, vol. 14, no. 4, pp. 320–331, 2018.

[29] S. Lakshminarayana, A. Praseed, and P. S. Thilagam, "Securing the IoT application layer from an MQTT protocol perspective: Challenges and research prospects," *IEEE Communications Surveys & Tutorials*, vol. 26, no. 4, pp. 2510–2546, 2024.

[30] G. Perrone, M. Vecchio, R. Pecori, and R. Giaffreda, "The day after Mirai: A survey on MQTT security solutions after the largest cyber-attack carried out through an army of IoT devices," in *Proc. 2nd Int. Conf. Internet of Things, Big Data and Security (IoTBDS)*, 2017, pp. 246–253.

[31] G. Nebbione and M. C. Calzarossa, "Security of IoT application layer protocols: Challenges and findings," *Future Internet*, vol. 12, no. 3, p. 55, 2020.

[32] S. U. A. Laghari, W. Li, S. Manickam, P. Nanda, A. K. Al-Ani, and S. Karuppayah, "Securing MQTT ecosystem: Exploring vulnerabilities, mitigations, and future trajectories," *IEEE Access*, vol. 12, pp. 139 273–139 289, 2024.

[33] A. Niruntasukrat, C. Issariyapat, P. Pongpaibool, K. Meesublak, P. Aiumsupucgul, and A. Panya, "Authorization mechanism for MQTT-based Internet of Things," in *Proc. IEEE Int. Conf. Communications Workshops (ICC)*, 2016, pp. 290–295.

[34] A. Rizzardi, S. Sicari, D. Miorandi, and A. Coen-Porisini, "AUPS: An open source AUthenticated Publish/Subscribe system for the Internet of Things," *Information Systems*, vol. 62, pp. 29–41, 2016.

[35] M. Dahlmanns, J. Pennekamp, I. B. Fink, B. Schoolmann, K. Wehrle, and M. Henze, "Transparent end-to-end security for publish/subscribe communication in cyber-physical systems," in *Proc. ACM Workshop on Secure and Trustworthy Cyber-Physical Systems (SaT-CPS)*, 2021, pp. 78–87.

[36] S. Andy, B. Rahardjo, and B. Hanindhito, "Attack scenarios and security analysis of MQTT communication protocol in IoT system," in *Proc. 4th Int. Conf. Electrical Engineering, Computer Science and Informatics (EECSI)*, 2017, pp. 1–6.

[37] S. H. Ramos, M. T. Villalba, and R. Lacuesta, "MQTT security: A novel fuzzing approach," *Wireless Communications and Mobile Computing*, vol. 2018, p. 8261746, 2018.

[38] D. Dinculeană and X. Cheng, "Vulnerabilities and limitations of MQTT protocol used between IoT devices," *Applied Sciences*, vol. 9, no. 5, p. 848, 2019.

[39] F. Buccafurri, V. De Angelis, and S. Lazzaro, "MQTT-A: A broker-bridging P2P architecture to achieve anonymity in MQTT," *IEEE Internet of Things Journal*, vol. 10, no. 17, pp. 15 443–15 463, 2023.

[40] L. Malina, G. Srivastava, P. Dzurenda, J. Hajny, and R. Fujdiak, "A secure publish/subscribe protocol for Internet of Things," in *Proc. 14th Int. Conf. Availability, Reliability and Security (ARES)*. ACM, 2019, pp. 1–10.

[41] A. Javadi, S. Rostampour, Y. Bendavid, P. Pahlevani, S. Sadeghi, N. Bagheri, H. K. Nazari, M. Reisslein, and F. H. P. Fitzek, "CMAP: Certificateless MQTT-based authentication protocol for medical IoT," *IEEE Access*, vol. 14, pp. 60 836–60 852, 2026.

A *Strings* de pesquisa por base de dados

Pesquisas executadas em 01-11-2026, restringidas a publicações de 2014 a 2026. O ACM Digital Library e a Web of Science não foram pesquisados (Secção 3.3); a *string* secundária não pôde ser executada no ScienceDirect por exceder o limite de operadores booleanos. Os grupos G1 a G3 são os da Tabela 5; nas *strings* secundárias acrescenta-se, com `AND`, o grupo G4.

IEEE Xplore (*Command Search*, campo *All Metadata*)

```
("All Metadata":"MQTT"OR "All Metadata":"MQTT-SN"OR "All Metadata":"MQ Telemetry Transport"OR
"All Metadata":"Message Queuing Telemetry Transport"OR "All Metadata":"Message Queue Telemetry
Transport") AND ("All Metadata":security OR "All Metadata":secure OR "All
Metadata":authentication OR "All Metadata":authorization OR "All Metadata":"access control"OR
"All Metadata":encryption OR "All Metadata":confidentiality OR "All Metadata":integrity OR "All
Metadata":privacy OR "All Metadata":attack* OR "All Metadata":vulnerabilit* OR "All
Metadata":intrusion) AND ("All Metadata":"Internet of Things"OR "All Metadata":IoT OR "All
Metadata":IIoT OR "All Metadata":"publish/subscribe"OR "All Metadata":"publish-subscribe"OR "All
Metadata":"machine-to-machine"OR "All Metadata":M2M)
Filtro: Year 2014-2026; Conferences, Journals.
```

Scopus (*Advanced document search*)

```
TITLE-ABS-KEY(("MQTT"OR "MQTT-SN"OR "MQ Telemetry Transport"OR "Message Queuing Telemetry
Transport"OR "Message Queue Telemetry Transport") AND ("security"OR "secure"OR
"authentication"OR "authorization"OR "access control"OR "encryption"OR "confidentiality"OR
"integrity"OR "privacy"OR attack* OR vulnerabilit* OR "intrusion") AND ("Internet of Things"OR
"IoT"OR "IIoT"OR "publish/subscribe"OR "publish-subscribe"OR "machine-to-machine"OR "M2M")) AND
PUBYEAR > 2013 AND PUBYEAR < 2027 AND DOCTYPE(ar OR cp) AND LANGUAGE(english OR portuguese)
Na string secundária, DOCTYPE(ar OR cp OR re), para incluir as revisões.
```

ScienceDirect (campo *Title, abstract or author-specified keywords*)

O ScienceDirect não suporta o carácter universal `*` e limita o número de operadores booleanos por campo; a *string* foi, por isso, dividida em duas consultas cujos resultados foram unidos:

```
(1) ("MQTT"OR "Message Queuing Telemetry Transport") AND (security OR authentication OR
authorization OR encryption) AND ("Internet of Things"OR IoT)

(2) ("MQTT"OR "Message Queuing Telemetry Transport") AND (attack OR attacks OR vulnerability OR
intrusion OR privacy) AND ("Internet of Things"OR IoT)
Filtro: Years 2014-2026; Article types: Research articles.
```

String secundária (revisões), no IEEE Xplore e no Scopus

```
<string principal> AND ("systematic literature"OR "systematic review"OR "literature review"OR
"survey")
```

B Extração de dados e referências dos estudos

A Tabela 17 resume a extração de dados de cada estudo analisado e identifica-o pela publicação, pelo DOI e pela versão do texto integral consultada; as secções citadas referem-se a essa versão. A

localização de cada célula das tabelas 10 e 12 está no ficheiro `report/rsl/rastreabilidade.md` do repositório.

Tabela 17. Extração de dados, publicação e versão consultada dos estudos e revisões analisados.

ID	Estudo	Cat.	Contributo principal	Avaliação reportada	Publicação; DOI; texto consultado
E01	Singh et al. [23]	C4	SMQTT e SMQTT-SN: KP/CP-ABE sobre ECC leve; o *broker* é o gerador de chaves (§III-B)	Três portáteis a simular dispositivos IoT (§VII-A)	CSNT 2015, pp. 746–751; `10.1109/CSNT.2015.16`; Editor (IEEE Xplore)
E02	Niruntasukrat et al. [33]	C3	Autorização baseada em OAuth 1.0a adaptada a nós restritos sem interface de utilizador	Plataforma IoT real; atraso de autorização em Arduino Mega e outros (§IV)	IEEE ICC Workshops 2016, pp. 290–295; `10.1109/ICCW.2016.7503802`; Editor (IEEE Xplore)
E03	Rizzardi et al. [34]	C3	AUPS: gestão de chaves por tópico e aplicação de políticas sobre o MQTT; código aberto (Apache 2.0)	Robustez (§IV-A); *overhead*, latência e computação em Raspberry Pi (§V)	Information Systems 62 (2016), pp. 29–41; `10.1016/j.is.2016.05.004`; Versão de autor (15 pp., paginação própria)
E04	Andy et al. [36]	C1	Cenários de ataque ao MQTT sem cifra; razões para a falta de segurança nas implementações	Demonstração de ataques	EECSI 2017, pp. 1–6; `10.1109/EECSI.2017.8239179`; Só o resumo
E05	Calabretta et al. [28]	C3	MQTT-Auth: AugPAKE para confidencialidade e dois *tokens* (autenticação e autorização por tópico); o *broker* decifra e recifra (§IV-A)	Dois *testbeds*: portáteis e UDOO Cortex-A9 (§V)	J. Commun. Softw. Syst. 14(4) (2018), pp. 320–331; `10.24138/jcomss.v14i4.604`; Editor (JCOMSS)
E06	Hernández Ramos et al. [37]	C1	Enquadramento de *fuzzing* baseado em *templates* para o MQTT	Resultados experimentais iniciais	Wirel. Commun. Mob. Comput. 2018, 8261746; `10.1155/2018/8261746`; Só o resumo
E07	Dinculeană e Cheng [38]	C5	Mapeamento *Value-to-HMAC*: confidencialidade e integridade com um só mecanismo; repetição fora do âmbito (§6)	Desempenho face a cifra simétrica em Onion Omega2+ (§3.1, §4.2)	Applied Sciences 9(5) (2019), 848; `10.3390/app9050848`; Editor (MDPI)
E08	Malina et al. [40]	C5	Três níveis com assinatura Schnorr sobre nível, tópico, identidade, dados e carimbo temporal (§4.5, Eq. 6)	Analítica: contagem de operações (§5.1)	ARES 2019, pp. 1–10; `10.1145/3339252.3340503`; PDF em formato ACM (10 pp.)
E09	Sadio et al. [24]	C5	AEAD ChaCha20-Poly1305 fim-a-fim para MQTT e MQTT-SN	Arduino UNO; memória e tempo de execução (§IV-B)	IOTSMS 2019, pp. 119–123; `10.1109/IOTSMS48152.2019.8939177`; Editor (IEEE Xplore)
E10	Vaccari et al. [21]	C1	SlowITe: DoS de baixa taxa que explora a configuração do servidor pelo cliente	Serviços MQTT reais, com e sem cifra (§5)	Sensors 20(10) (2020), 2932; `10.3390/s20102932`; PubMed Central (PMC7285273)

ID	Estudo	Cat.	Contributo principal	Avaliação reportada	Publicação; DOI; texto consultado
E11	Vaccari et al. [22]	C7	MQTTset: conjunto de dados de tráfego MQTT legítimo e de ataques	Sistema de deteção por ML (§3.2, §4)	Sensors 20(22) (2020), 6578; 10.3390/s20226578; PubMed Central (PMC7698741)
E12	Segarra et al. [6]	C6	MQT-TZ: *broker* em ARM TrustZone; TLS mútuo e cifra em duas camadas	Micro e macro *benchmarks*; cargas de uma aplicação médica	SRDS 2020, pp. 256–265; 10.1109/SRDS51746.2020.00033; Pré-publicação (arXiv:2007.12442v2)
E13	Dahlmanns et al. [35]	C5	ENTRUST: chave por tópico distribuída por um servidor de chaves com ACL; contador por publicador contra duplicados (§5.2–5.3)	RedBear Duo (Cortex-M3) e Mosquitto (§7)	ACM SaT-CPS 2021, pp. 78–87; 10.1145/3445969.3450423; Cópia de autor
E14	Spielvogel et al. [10]	C6	O *broker* só reencaminha por ligações com o nível de segurança exigido	Protótipo; medições de *overhead* (§II-C)	STM 2021, LNCS, pp. 145–162; 10.1007/978-3-030-91859-0_8; Pré-publicação (arXiv:2109.01169)
E15	Prantl et al. [9]	C6	Impacto do TLS 1.2 no MQTT: débito, estabelecimento de ligação, energia	ESP8266; todos os níveis de QoS (§4)	ACM/SPEC ICPE 2021, pp. 241–248; 10.1145/3427921.3450253; Atas ICPE (SPEC Research)
E16	Van Glabbeek et al. [3]	C5	Três opções com assinatura Schnorr e carimbo temporal; *broker* honesto mas curioso, CA confiável (§3.1, §4.3)	−80 % *overhead* de comunicação e −40 % computacional face ao MQTTS (Raspberry Pi)	Sensors 22(19) (2022), 7391; 10.3390/s22197391; PubMed Central (PMC9572294)
E17	Buccafurri et al. [39]	C8	MQTT-A: anonimato de *publishers* e subscritores via *bridges*	*Brokers* em nuvem em vários países; latência e *goodput* (§VIII)	IEEE IoT J. 10(17) (2023), pp. 15443–15463; 10.1109/JIOT.2023.3264019; Editor (IEEE Xplore)
E18	Alotaibi et al. [25]	C7	Deteção distribuída de anomalias com H2O (melhor: XGBoost)	MSE, RMSE, erro por classe, *log loss* (§4.3)	Sensors 24(5) (2024), 1638; 10.3390/s24051638; PubMed Central (PMC10935133)
E19	Javadi et al. [41]	C2	CMAP: autenticação mútua sem certificados sobre ECC, entre dispositivo e *broker*	Prova no modelo do oráculo aleatório (§V-B); Raspberry Pi com Mosquitto; NS-3	IEEE Access 14 (2026), pp. 60836–60852; 10.1109/ACCESS.2026.3684371; Editor (IEEE Access)
—	Perrone et al. [30]	—	Revisão relacionada (Secção 4)	—	IoTBDS 2017, pp. 246–253; 10.5220/0006287302460253; Editor (SciTePress)

ID	Estudo	Cat.	Contributo principal	Avaliação reportada	Publicação; DOI; texto consultado
—	Nebbione e Calzarossa [31]	—	Revisão relacionada (Secção 4)	—	Future Internet 12(3) (2020), 55; 10.3390/fi12030055; Editor (MDPI)
—	Hintaw et al. [20]	—	Revisão relacionada (Secção 4)	—	IETE J. Res. 69(6) (2023), pp. 3368–3397; 10.1080/03772063.2021.1912651; Só o resumo e a introdução
—	Lakshminarayana et al. [29]	—	Revisão relacionada (Secção 4)	—	IEEE Commun. Surv. Tutor. 26(4) (2024), pp. 2510–2546; 10.1109/COMST.2024.3372630; Editor (IEEE Xplore)
—	Laghari et al. [32]	—	Revisão relacionada (Secção 4)	—	IEEE Access 12 (2024), pp. 139273–139289; 10.1109/ACCESS.2024.3412030; Editor (IEEE Access)